

Section 07



Industrial Security (Bachelor)

Section 07 – Risk Management

Risk Management

Lecture Notes

Department of Computer Science

1 Risk Fundamentals

2 Methodologies

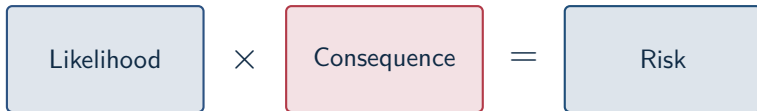
By the end of this section you will be able to

- Construct and interpret a qualitative risk matrix for an industrial site.
- Apply Cyber-HAZOP / Cyber-PHA techniques.
- Distinguish IT risk from safety risk.
- Recognise the Consequence-Driven Cyber-Informed Engineering (CCE) approach.

1

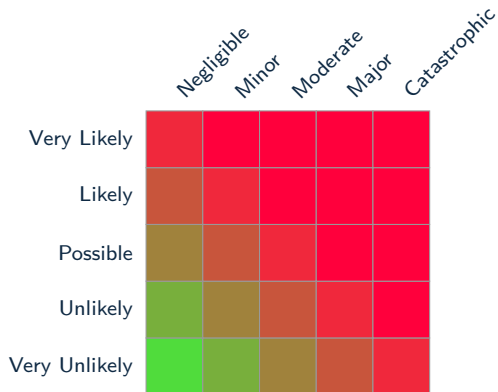
Risk Fundamentals

Section 07 – Risk Management



Consequence dimensions

Safety, environment, production loss, reputation, regulatory.
Likelihood depends on adversary capability *and* exploit difficulty.

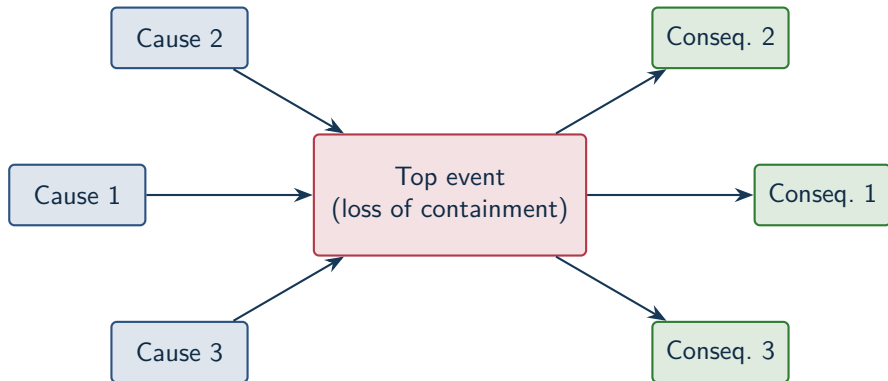


Useful for quick communication; risk of false precision and gaming.

2

Methodologies

Section 07 – Risk Management



Barriers on the left prevent causes; barriers on the right mitigate consequences.

No

More

Less

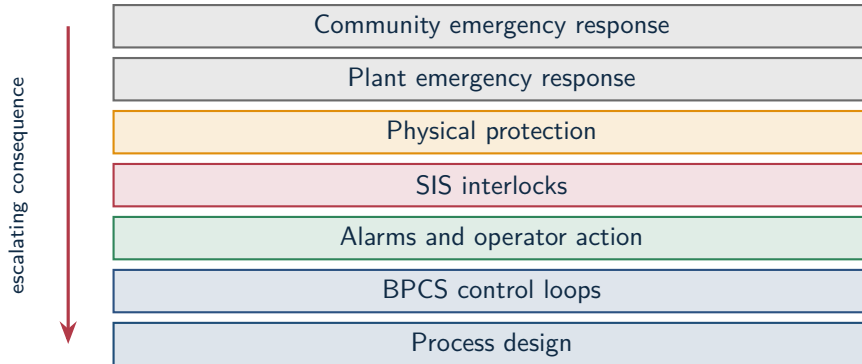
Reverse

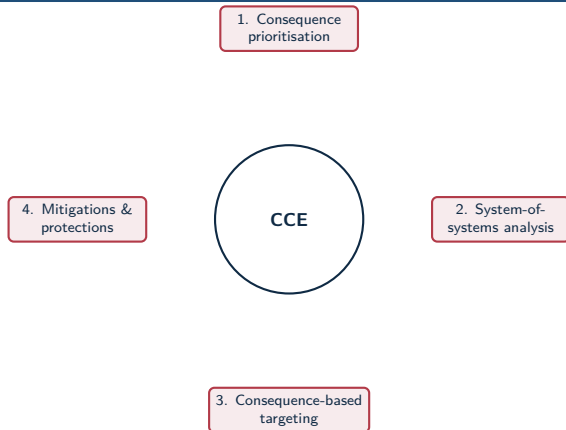
As well as

For each node, ask:

“What if an **attacker** caused the deviation *[guide word] [parameter]?*”

Examples: no flow → attacker closes inlet valve; high pressure → attacker disables relief actuator.





INL methodology

“What would I do if I were the adversary?” Engineer out the worst consequences.

Avoid

remove function

Mitigate

reduce L or C

Transfer

insure / contract

Accept

signed-off

Acceptance is legitimate

But it must be reviewed periodically – threats evolve.

Loss event frequency

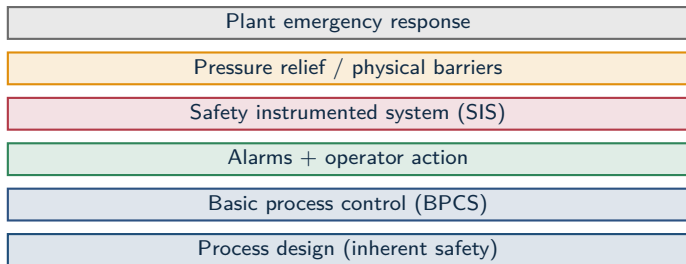
×

Loss magnitude

= Annualised loss expectancy (ALE)

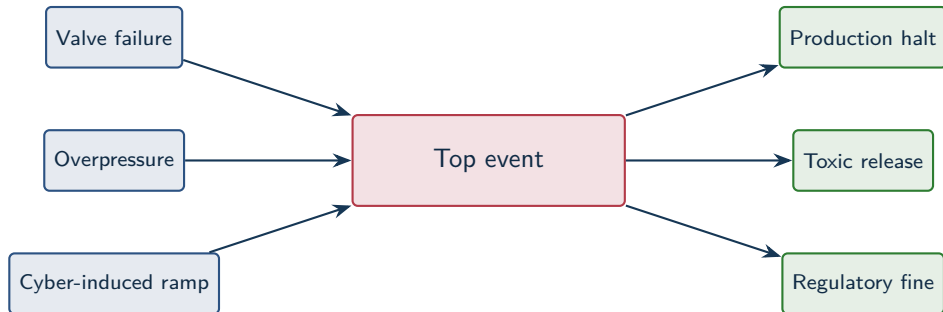
When FAIR earns its keep

When the board asks “how much does this risk actually cost us?” – and a heat-map is no longer enough.



Independence is the value

Each layer must be *independent of the next* – otherwise one common-cause failure removes them all.



Barriers on the left prevent causes; barriers on the right mitigate consequences.

	Qualitative	Quantitative
Speed	Hours	Days to weeks
Data needed	Workshop + expert judgement	Frequency & impact data
Output	Heat map / risk matrix	Loss curve in money
Use cases	Initial triage	Board / insurance / capex
Pitfalls	False precision	Garbage in $\Rightarrow$ garbage out

- First-party: forensics, IR retainer, business interruption.
- Third-party: liability, regulator response.
- Typical exclusions: nation-state acts of war, unpatched known CVEs, missing MFA.
- Insurers now drive a minimum control baseline (MFA, EDR, backups).

Caution

Insurance is a backstop, not a control. Premiums rise sharply if your baseline is weak.

Risk	L	Impact	Sc.	Mitigation
Ransom. Hist.	Likely	Major	H	Immutable backups, EDR
SIS reprogram	Unlikely	Catastr.	H	Key-switch + signed dl
Vendor abuse	Possible	Major	H	MFA brokered access
USB malware	Likely	Moderate	M	USB block, allow-listing
PLC firmware CVE	Possible	Major	M	Vendor patch / IPS rule

★ Key Takeaway: What to remember from this section

- Industrial risk has dimensions IT does not: safety, environment, regulatory.
- Cyber-HAZOP integrates security into the language of process safety teams.
- LOPA reminds us that several independent layers must fail for a disaster.
- CCE asks: how would the adversary win? – and re-engineers to remove the winning move.

End of Section 07



Risk Management

Questions and discussion